



# AGENTIC AI-SOC

AUTONOMOUS SECURITY OPERATIONS

**Autonomous Threat Hunting, Attack-Chain Reasoning  
& Incident Response Platform**

THREAT HUNTING • AI REASONING • CTI • MITRE ATT&CK

**Dahamsi Risadi Vidara**

2026

Evidence-grounded • Human-in-the-loop • Research Prototype

## Abstract

Security Operations Centres (SOCs) process large volumes of security telemetry and alerts, making timely identification and investigation of potentially malicious activity an important operational challenge. This project presents **Agentic AI-SOC**, an evidence-grounded multi-agent platform designed to support threat hunting, attack-chain reasoning, risk assessment, and incident-response decision making.

The proposed system ingests security logs in JSON, JSONL, and CSV formats and applies context-aware detection to identify potentially significant activities. Detected events are correlated temporally and by relevant entities to construct potential attack chains. The platform further enriches investigations using a local Cyber Threat Intelligence (CTI) knowledge base, maps observed activities to the MITRE ATT&CK framework, calculates an evidence-weighted risk score with uncertainty considerations, and produces a structured security decision. A local **Llama 3.1 8B** model, hosted through Ollama, is used to generate evidence-grounded natural-language reasoning, while response recommendations remain subject to human approval.

Evaluation was conducted using a **45-scenario unseen synthetic hold-out dataset**. The complete Agentic AI-SOC achieved **100% accuracy, 100% precision, 100% recall, and 100% F1-score**, with a **0% false-positive rate** on the evaluated scenarios. MITRE ATT&CK mapping achieved **84.62% precision, 100% recall, and 91.67% F1-score**. In comparison, the implemented rule-based baseline achieved **88.89% accuracy, 100% precision, 75% recall, and 85.71% F1-score**. Additional ablation and stress-testing experiments were conducted to examine the contribution of individual system components.

The findings demonstrate the feasibility of combining deterministic security controls, contextual event correlation, CTI enrichment, attack-chain reasoning, dynamic risk assessment, and evidence-grounded local LLM reasoning within a single SOC research prototype. However, the reported performance is limited to the constructed synthetic evaluation scenarios and current decision logic and **must not be interpreted as evidence of equivalent real-world SOC accuracy**.

# CONTENTS

## **1. Introduction & Literature Review 9**

- 1.1 Introduction 9
- 1.2 Background and Motivation 9
- 1.3 Problem in Brief 10
- 1.4 Aim & Objectives 11
  - 1.4.1 Aim 11
  - 1.4.2 Objectives 11
- 1.5 Technical and Operational Scope 12
- 1.6 Deliverables 13
- 1.7 Literature Review 14

## **2. Analysis 19**

- 2.1 Problem Definition 19
- 2.2 Analysis of Existing Problem 20
- 2.3 Limitations and Assumptions 21
- 2.4 SWOT Analysis 22
- 2.5 Use Case Analysis 22
- 2.6 User Stories 24
- 2.7 Requirements Engineering 25
- 2.8 Requirement-to-Component Mapping 27
- 2.9 Analysis Summary 27

## **3. Design 29**

- 3.1 Design Techniques 29
- 3.2 System Design Process 30
- 3.3 System Architecture Overview 32
- 3.4 Core System Components 34
- 3.5 Data Flow Design 35
- 3.6 Attack-Chain Correlation Design 36
- 3.7 Risk Assessment Design 36
- 3.8 Security Decision Design 37
- 3.9 LLM Reasoning Design 38
- 3.10 Evidence Grounding Design 39
- 3.11 Human-in-the-Loop Response Design 40
- 3.12 Dashboard Design 40
- 3.13 Design Safety and Governance 41
- 3.14 Design Summary 41

## **4. Product Implementation 43**

- 4.1 Development Environment 43
- 4.2 Module Implementation 43
- 4.3 Dashboard Implementation 44
- 4.4 Local LLM and Evidence Grounding 49

## **5. Validation 50**

- 5.1 Validation Strategy 50

|                          |    |
|--------------------------|----|
| 5.2 Hold-out Evaluation  | 50 |
| 5.3 Baseline Comparison  | 52 |
| 5.4 Ablation Evaluation  | 53 |
| 5.5 Stress Testing       | 54 |
| 5.6 Dashboard Validation | 55 |
| 5.7 Validation Summary   | 56 |

## **6. Critical Review & Conclusion 57**

|                                       |    |
|---------------------------------------|----|
| 6.1 Critical Review                   | 57 |
| 6.2 Key Findings                      | 58 |
| 6.3 Future Work                       | 59 |
| 6.3.1 Larger and Independent Datasets | 59 |
| 6.3.2 Real-Time Security Data         | 59 |
| 6.3.3 Expanded Threat Intelligence    | 59 |
| 6.3.4 Improved Risk Calibration       | 59 |
| 6.3.5 Advanced Attack-Graph Reasoning | 60 |
| 6.3.6 Production SOC Integration      | 60 |
| 6.3.7 Improved Multiclass Evaluation  | 60 |
| 6.4 Closing Executive Summary         | 60 |
| 6.5 Conclusion                        | 61 |

## **References / Bibliography 62**

## **Appendices 63**

|                                              |    |
|----------------------------------------------|----|
| Appendix A – Project Directory Structure     | 63 |
| Appendix B – Evaluation Artifacts            | 63 |
| Appendix C – Demonstration Note              | 64 |
| Appendix D – Research Caveat                 | 64 |
| Appendix E – Key Demonstration Configuration | 65 |

## List of Figures/Tables

### List of Figures

| Figure No. | Figure Name                                                       | Chapter / Section |
|------------|-------------------------------------------------------------------|-------------------|
| Figure 1   | Agentic AI-SOC Dashboard – Incident Overview                      | Chapter 4         |
| Figure 2   | Security Decision and Risk Level                                  | Chapter 4         |
| Figure 3   | Evidence-Weighted Dynamic Risk Assessment                         | Chapter 4         |
| Figure 4   | Attack Chain and AI Security Assessment                           | Chapter 4         |
| Figure 5   | Incident Response Recommendations                                 | Chapter 4         |
| Figure 6   | MITRE ATT&CK, Threat Intelligence and Incident Response Dashboard | Chapter 4         |
| Figure 7   | Incident Response Recommendations, Uncertainty and LLM Status     | Chapter 4         |

### List of Tables

| Table No. | Table Name                                 | Chapter / Section |
|-----------|--------------------------------------------|-------------------|
| Table 1   | Glossary of Cybersecurity and AI-SOC Terms | Chapter 1         |
| Table 2   | Functional and Non-Functional Requirements | Chapter 2         |
| Table 3   | Core Agent and Module Responsibilities     | Chapter 3         |
| Table 4   | Hold-out Evaluation Results                | Chapter 5         |
| Table 5   | Baseline Comparison                        | Chapter 5         |
| Table 6   | Ablation Evaluation Results                | Chapter 5         |
| Table 7   | Stress-Test Summary                        | Chapter 5         |

## Glossary of Terms

| Term                           | Definition                                                                                             |
|--------------------------------|--------------------------------------------------------------------------------------------------------|
| <b>SOC</b>                     | Security Operations Centre.                                                                            |
| <b>Agentic AI</b>              | AI architecture using specialised coordinated components.                                              |
| <b>CTI</b>                     | Cyber Threat Intelligence.                                                                             |
| <b>MITRE ATT&amp;CK</b>        | Knowledge base and framework describing adversary tactics and techniques.                              |
| <b>IOC</b>                     | Indicator of Compromise.                                                                               |
| <b>Attack Chain</b>            | Correlated sequence of security observations that may represent related stages of an incident.         |
| <b>Risk Score</b>              | Evidence-weighted numerical representation of security risk.                                           |
| <b>LLM</b>                     | Large Language Model.                                                                                  |
| <b>Evidence Grounding</b>      | Checking generated AI reasoning against the evidence supplied to the reasoning process.                |
| <b>Human-in-the-Loop</b>       | Human validation or approval before potentially disruptive response actions.                           |
| <b>SIEM</b>                    | Security Information and Event Management.                                                             |
| <b>EDR</b>                     | Endpoint Detection and Response.                                                                       |
| <b>SOAR</b>                    | Security Orchestration, Automation and Response.                                                       |
| <b>FPR</b>                     | False Positive Rate.                                                                                   |
| <b>TP</b>                      | True Positive.                                                                                         |
| <b>TN</b>                      | True Negative.                                                                                         |
| <b>FP</b>                      | False Positive.                                                                                        |
| <b>FN</b>                      | False Negative.                                                                                        |
| <b>MITRE Technique</b>         | A documented adversary behaviour represented within the MITRE ATT&CK framework.                        |
| <b>Threat Hunting</b>          | Proactive investigation of security data to identify potentially malicious activity.                   |
| <b>Context-Aware Detection</b> | Detection that considers surrounding event context rather than relying only on an isolated rule match. |
| <b>Risk Assessment</b>         | Process of evaluating evidence and contextual factors to determine the                                 |

| Term                     | Definition                                                                                  |
|--------------------------|---------------------------------------------------------------------------------------------|
| <b>Incident Response</b> | security risk associated with an investigation.                                             |
|                          | Activities performed to investigate, contain, mitigate and recover from security incidents. |

# 1. Introduction & Literature Review

## 1.1 Introduction

Modern organisations generate large volumes of security telemetry from endpoints, servers, authentication systems, applications, cloud environments, and network infrastructure. Security Operations Centres (SOCs) are responsible for monitoring this telemetry, identifying potentially malicious activity, investigating security incidents, and supporting appropriate incident-response actions.

One of the main challenges in SOC operations is that security events do not always provide sufficient meaning when considered individually. A single PowerShell execution, failed authentication attempt, system-discovery command, or external network connection may be legitimate when viewed independently. However, several related events occurring on the same host, user account, or network context may indicate a potentially significant security sequence.

Agentic AI-SOC was designed to investigate whether a coordinated multi-stage architecture can improve threat investigation and incident-response decision support compared with a conventional rule-based workflow. The platform combines deterministic detection, contextual event correlation, cyber threat intelligence (CTI), MITRE ATT&CK mapping, dynamic risk assessment, attack-chain reasoning, local Large Language Model (LLM) reasoning, and human-approved response recommendations.

The system is designed as a research prototype rather than a replacement for human SOC analysts. Its purpose is to organise security evidence, identify relationships between events, provide an explainable assessment, and support analysts in making informed response decisions.

## 1.2 Background and Motivation

Traditional SOC environments commonly depend on predefined detection rules and alert-generation mechanisms. Rule-based detection provides deterministic and auditable behaviour because a finding can be traced back to a defined condition. However, security events can have different meanings depending on their surrounding context.

For example, PowerShell activity may be part of normal system administration, while PowerShell containing encoded commands or suspicious download behaviour may represent a substantially different security situation. Similarly, a failed authentication attempt may be insignificant when occurring once, but repeated failures combined with other suspicious activity may require further investigation.

This project is therefore motivated by the need to combine **deterministic detection with contextual reasoning**. Agentic AI-SOC correlates security observations using temporal and entity relationships, enriches investigations using CTI, maps relevant activity to MITRE ATT&CK techniques, and calculates an evidence-weighted risk score.

Another motivation is the increasing use of LLMs for security analysis. Although LLMs can produce understandable explanations, their output should not automatically be treated as authoritative security evidence. Agentic AI-SOC therefore separates the authoritative risk assessment from the language-generation component. The LLM receives the available evidence and risk context and produces an evidence-grounded explanation rather than independently determining the final risk.

## 1.3 Problem in Brief

The core problem addressed by this project is the investigation of security events that may appear ambiguous when analysed individually but become more meaningful when considered as a related sequence.

A conventional rule-based workflow may generate several independent alerts without clearly explaining how those alerts are related. This can increase investigation effort and make it difficult to understand the possible progression of an incident.

Agentic AI-SOC addresses this problem by correlating observations using factors such as:

- Event time
- Host
- User
- Source IP
- Destination IP
- Detection type
- MITRE ATT&CK technique
- CTI information
- Relationship confidence

However, correlation is not treated as conclusive proof of an attack. The system explicitly preserves uncertainty because an external network connection, authentication event, or discovery command may have legitimate explanations.

## 1.4 Aim & Objectives

### 1.4.1 Aim

The primary aim of this project is to design and implement an evidence-grounded multi-agent AI-SOC platform for autonomous threat hunting, attack-chain reasoning, risk assessment, and incident-response decision support.

### 1.4.2 Objectives

The main objectives are:

1. To develop a security-log ingestion and normalisation component supporting JSON, JSONL, and CSV formats.
2. To develop context-aware detection rules for identifying potentially significant security activities.
3. To correlate security findings temporally and by relevant entities.
4. To integrate a local Cyber Threat Intelligence knowledge base and IOC matching.
5. To map relevant security findings to the MITRE ATT&CK framework.
6. To calculate an evidence-weighted risk score while considering uncertainty.
7. To generate structured benign, suspicious, or malicious security decisions.

8. To provide evidence-grounded LLM reasoning using a locally hosted Llama 3.1 8B model.
9. To generate incident-response recommendations while maintaining human approval before disruptive actions.
10. To evaluate the system using an unseen synthetic hold-out dataset and a rule-based baseline.
11. To measure the contribution of selected system components using ablation and stress-testing experiments.

## 1.5 Technical and Operational Scope

The technical scope of Agentic AI-SOC includes the following components:

### Log Processing

- JSON security logs
- JSONL security logs
- CSV security logs
- Event normalisation
- Standardised security-event fields

### Threat Detection

- Context-aware PowerShell detection
- System-discovery detection
- Failed-authentication detection
- External-network activity detection
- Multi-stage suspicious activity detection

### Attack-Chain Analysis

- 15-minute correlation window
- Temporal relationships
- Host relationships
- User relationships
- Source-IP relationships
- Relationship confidence

## Threat Intelligence

- Local CTI knowledge base
- IOC matching
- Suspicious and malicious indicator classification
- Technique-related CTI enrichment

## MITRE ATT&CK

- Technique identification
- Technique mapping
- ATT&CK-based investigation context

## Risk Assessment

- Evidence contribution
- Temporal correlation
- Entity correlation
- MITRE coverage
- CTI contribution
- Context modifiers
- Uncertainty penalty

## AI Reasoning

- Ollama local runtime
- Llama 3.1 8B
- Evidence-grounded reasoning
- Grounding validation
- Authoritative risk preservation

## Application Layer

- FastAPI backend
- Uvicorn server
- Streamlit analyst dashboard

## Response

- Incident-response recommendations
- Human approval workflow
- No automatic destructive action

## 1.6 Deliverables

The major deliverables of the project are:

1. A modular Agentic AI-SOC source-code implementation.
2. A security-log ingestion and normalisation module.
3. A context-aware detection engine.
4. An investigation agent.
5. A Cyber Threat Intelligence knowledge base.
6. MITRE ATT&CK mapping functionality.
7. An attack-chain correlation module.
8. An evidence-weighted risk assessment agent.
9. A security decision agent.
10. An AI reasoning and local LLM component.
11. An incident-response recommendation agent.
12. A FastAPI backend.
13. A Streamlit security-operations dashboard.
14. Synthetic security-event datasets.
15. Hold-out, baseline, ablation, and stress-testing evaluation scripts.
16. Evaluation results and supporting evidence.
17. Dashboard screenshots demonstrating the implemented workflow.
18. Technical documentation describing the architecture, implementation, validation, limitations, and future work.

## 1.7 Literature Review

### 1.7.1 Security Operations Centres and Security Monitoring

A Security Operations Centre provides a central operational function for monitoring security events and investigating potentially malicious activity. SOC workflows commonly involve collecting security telemetry, identifying alerts, investigating evidence, determining the significance of an incident, and supporting response activities (Nelson et al., 2025; Habibzadeh et al., 2026). A major challenge in SOC environments is alert interpretation. Security telemetry may contain large numbers of events, while only a smaller proportion may require investigation. Therefore, an effective investigation process needs to distinguish potentially meaningful activity from normal or expected behaviour.

Agentic AI-SOC addresses this problem by combining detection with subsequent investigation and contextual analysis rather than treating every detection as an isolated incident. (Rieger et al., 2026).

---

### 1.7.2 Rule-Based Threat Detection

Rule-based detection is an important component of security monitoring because it provides deterministic and auditable detection logic. A rule can specify conditions under which a security event should generate a finding. (Nelson et al., 2025).

The Agentic AI-SOC detection engine uses this principle while adding contextual classification. For example, PowerShell activity is not automatically treated as malicious. The system distinguishes administrative PowerShell behaviour from higher-risk indicators such as encoded execution or suspicious download-related commands.

This approach allows deterministic rules to remain transparent while reducing the possibility that legitimate administrative activity is automatically treated as malicious.

---

### 1.7.3 Security Event Correlation and Attack-Chain Analysis

Individual security events may provide limited information about an incident. Correlation attempts to identify relationships between multiple observations using attributes such as time, host, user, and network information. (Nelson et al., 2025; Rieger et al., 2026).

Agentic AI-SOC implements a 15-minute correlation window and evaluates relationships between findings. Stronger relationships can be established when multiple findings involve the same host, user, or relevant network entities.

The resulting attack chain represents an **investigative hypothesis**, rather than definitive proof of an attack. This distinction is important because related events may still have legitimate explanations.

---

#### 1.7.4 Cyber Threat Intelligence

Cyber Threat Intelligence provides additional context that can help security analysts interpret indicators and observed behaviour. Indicators may include IP addresses, domains, hashes, or other observable artefacts associated with suspicious activity. (Alaeifar et al., 2024).

Agentic AI-SOC contains a local CTI knowledge base that supports both technique-related information and indicator-based matching. CTI information is incorporated into the investigation and risk-assessment process rather than being used as the only basis for a security decision.

This design allows CTI to act as an enrichment layer alongside observed security evidence.

---

#### 1.7.5 MITRE ATT&CK Framework

MITRE ATT&CK provides a structured representation of adversary tactics and techniques. Mapping observed activity to ATT&CK techniques can make security investigations easier to understand because individual events can be represented using a recognised cybersecurity vocabulary. (MITRE, 2026).

Agentic AI-SOC incorporates MITRE ATT&CK mapping into the investigation workflow. Examples implemented within the prototype include techniques associated with PowerShell, system discovery, brute-force activity, and application-layer network communication.

ATT&CK mapping is therefore used as an explanatory and analytical layer rather than as independent proof that an attack occurred.

---

### 1.7.6 Artificial Intelligence and Large Language Models in SOC Operations

Artificial intelligence and Large Language Models can assist with the interpretation and summarisation of security information. An LLM can transform structured evidence into a human-readable explanation and can help analysts understand relationships between different observations. (Habibzadeh et al., 2026; Rieger et al., 2026).

However, language models can produce unsupported statements if they are allowed to generate conclusions without sufficient evidence. For a security operations system, this creates a requirement for evidence grounding and clear separation between observed evidence and generated interpretation. (Rieger et al., 2026; Tabassi, 2023)

Agentic AI-SOC addresses this by providing the LLM with the available evidence and authoritative risk assessment. The LLM is therefore used primarily as a reasoning and explanation component rather than as the final authority for risk.

---

### 1.7.7 Agentic AI Architecture for Cybersecurity

An agentic architecture divides a complex workflow into specialised components. Instead of relying on a single processing stage, different components can perform detection, investigation, CTI enrichment, risk assessment, decision making, reasoning, and response recommendation. (Habibzadeh et al., 2026).

The Agentic AI-SOC architecture follows this approach through specialised modules including the Detection Engine, Investigation Agent, CTI Knowledge Base, Risk Assessment Agent, Decision Agent, AI Reasoning Agent, LLM Reasoning Engine, and Response Agent.

This modular design also supports independent testing and ablation evaluation because individual components can be removed or modified to examine their contribution to the overall workflow.

---

### 1.7.8 Evidence Grounding and Human-in-the-Loop Security

Security decisions can have operational consequences, particularly when actions involve host isolation, network blocking, or account investigation. For this reason, the proposed system does not allow the language model to independently trigger destructive actions. (Tabassi, 2023; Nelson et al., 2025).

The response layer produces recommendations and maintains a **PENDING\_HUMAN\_APPROVAL** state for response actions. This preserves human oversight while still allowing the platform to automate evidence organisation and recommendation generation.

Similarly, the LLM output is checked against the supplied evidence through a grounding mechanism. The dashboard exposes the grounding status so that the analyst can distinguish generated reasoning from the underlying evidence. (Rieger et al., 2026).

---

### 1.7.9 Research Gap

The reviewed concepts demonstrate that SOC detection, event correlation, CTI, ATT&CK mapping, risk assessment, AI reasoning, and human oversight can each contribute to security investigation. However, the specific research prototype developed in this project focuses on combining these components into a single coordinated workflow. (Nelson et al., 2025; Alaeifar et al., 2024; MITRE, 2026; Habibzadeh et al., 2026).

The main research focus of Agentic AI-SOC is therefore the integration of **multi-agent investigation, attack-chain correlation, evidence-weighted risk assessment, CTI enrichment, MITRE ATT&CK mapping, local LLM reasoning, and human-approved response recommendations**.

The project evaluates this integrated approach against a rule-based baseline using an unseen synthetic hold-out dataset, together with ablation and stress-testing experiments. The evaluation is deliberately limited to the constructed scenarios and is not presented as evidence of real-world enterprise SOC performance.

## 2. Analysis

### 2.1 Problem Definition

The target problem addressed by Agentic AI-SOC is the investigation of security events that may appear individually ambiguous but become more meaningful when considered collectively. In a conventional security-monitoring workflow, different events may generate separate alerts without providing sufficient context about how those events are related.

For example, a PowerShell execution, a system-discovery command, a failed authentication attempt, and an external network connection may each have legitimate explanations when considered independently. However, when multiple observations occur within a short time period and share relevant entities such as a host, user, or source IP, they may represent a potentially significant security sequence.

The proposed system therefore needs to perform more than simple alert generation. It must:

- collect and normalise security events;
- identify potentially significant activities;
- correlate related observations;
- enrich findings with CTI;
- map relevant activity to MITRE ATT&CK;
- calculate an evidence-weighted risk score;
- represent uncertainty;
- produce an explainable security decision; and
- provide response recommendations while retaining human control.

The system must also avoid treating individual indicators as conclusive evidence. For example, external network activity does not independently prove command-and-control activity, and an authentication event does not independently prove successful initial access. The analysis therefore distinguishes **observed evidence** from **investigative hypotheses**.

The problem can consequently be expressed as:

**How can multiple heterogeneous security observations be combined into an evidence-grounded and explainable investigation workflow that supports threat**

**detection and incident-response decision making while maintaining human oversight?**

---

## **2.2 Analysis of the Existing Problem**

Traditional rule-based SOC workflows are useful because their detection logic is deterministic and auditable. However, they can become limited when an incident consists of several related activities rather than a single clearly malicious event.

The main analytical challenges identified for this project are:

### **2.2.1 Alert Fragmentation**

Security events may be generated by different systems and may initially appear unrelated. Without correlation, the analyst may need to manually determine whether the events form part of the same activity.

### **2.2.2 Context Dependence**

The same command or event can have different meanings depending on context. For example, administrative PowerShell activity may be legitimate, while PowerShell containing encoded execution or suspicious download behaviour requires additional investigation.

### **2.2.3 Investigation Complexity**

An analyst may need to combine detection findings, host information, user information, network activity, CTI, and ATT&CK techniques before reaching a decision.

### **2.2.4 Risk Interpretation**

A security decision should not depend on a single signal. Evidence strength, temporal relationships, entity relationships, ATT&CK coverage, CTI information, context, and uncertainty need to be considered together.

### **2.2.5 Explainability**

A SOC analyst needs to understand why a system produced a particular assessment. Therefore, Agentic AI-SOC maintains evidence and uncertainty information rather than producing only a final label.

### 2.2.6 Response Safety

Security-response actions such as host isolation or network blocking can have operational consequences. The system therefore produces response recommendations and requires human approval before disruptive actions.

---

## 2.3 Limitations and Assumptions

The following limitations and assumptions apply to the current research prototype:

1. **Synthetic Evaluation Data**

The evaluation datasets consist of constructed security scenarios. Therefore, evaluation results represent the behaviour of the implemented system on those scenarios rather than arbitrary enterprise environments.

2. **Limited CTI Coverage**

The project uses a local CTI knowledge base. It does not represent the complete range of indicators and threat intelligence available in operational environments.

3. **Local LLM as a Prototype Component**

Llama 3.1 8B is used as a locally hosted reasoning component. Its output is treated as generated reasoning rather than authoritative security evidence.

4. **External Network Activity**

An external network connection does not independently prove command-and-control activity. Additional evidence is required before such an interpretation is made.

5. **Authentication Activity**

Authentication failures or authentication-related observations do not independently prove successful initial access.

6. **Attack-Chain Relationships**

Correlations between findings represent investigative hypotheses. Stronger relationships are established when relevant evidence such as shared hosts, users, source IPs, and temporal proximity is available.

7. **Production Deployment**

A production SOC deployment would require additional telemetry, SIEM/EDR integrations, larger CTI sources, authentication controls, response integrations, monitoring, logging, and operational governance.

8. **Human Oversight**

The response component is designed around human approval. The current system does not automatically execute destructive containment actions.

---

2.4 SWOT Analysis

| Area          | Analysis                                                                                                                                                                                                 |
|---------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths     | Modular multi-agent architecture; contextual event correlation; CTI enrichment; MITRE ATT&CK mapping; evidence-weighted risk assessment; local LLM reasoning; human approval before disruptive response. |
| Weaknesses    | Synthetic evaluation data; limited CTI coverage; prototype-level response integrations; dependency on the quality and completeness of supplied telemetry.                                                |
| Opportunities | SIEM and EDR integration; larger external CTI feeds; richer attack-graph analytics; real-world validation; additional security telemetry sources; improved risk calibration.                             |
| Threats       | Adversarial or manipulated telemetry; novel attack behaviour; incomplete logs; false relationships caused by insufficient context; unsupported LLM claims if grounding controls fail.                    |

The SWOT analysis indicates that the architecture provides several technical capabilities while also highlighting the gap between a controlled research prototype and a production SOC environment.

---

## 2.5 Use Case Analysis

The main use cases define how the different system components contribute to the overall SOC workflow.

| ID    | Use Case                  | Primary Component     | Description                                                                              |
|-------|---------------------------|-----------------------|------------------------------------------------------------------------------------------|
| UC-01 | Ingest Security Logs      | Log Ingestor          | Reads JSON, JSONL and CSV security events and converts them into a normalised structure. |
| UC-02 | Detect Security Activity  | Detection Engine      | Applies context-aware detection rules to identify potentially significant events.        |
| UC-03 | Correlate Attack Activity | Attack-Chain Module   | Identifies temporal and entity relationships between findings.                           |
| UC-04 | Investigate Incident      | Investigation Agent   | Combines findings and supporting evidence for investigation.                             |
| UC-05 | Enrich with CTI           | CTI Knowledge Base    | Searches for relevant techniques and indicators.                                         |
| UC-06 | Map ATT&CK                | MITRE Module          | Maps supported findings to MITRE ATT&CK techniques.                                      |
| UC-07 | Assess Risk               | Risk Assessment Agent | Calculates evidence-weighted risk and uncertainty.                                       |
| UC-08 | Make Security Decision    | Decision Agent        | Produces a benign, suspicious, or malicious decision.                                    |
| UC-09 | Explain Evidence          | AI/LLM Agent          | Produces structured and natural-language evidence-grounded reasoning.                    |

| ID    | Use Case              | Primary Component   | Description                                                                             |
|-------|-----------------------|---------------------|-----------------------------------------------------------------------------------------|
| UC-10 | Recommend Response    | Response Agent      | Generates response recommendations subject to human approval.                           |
| UC-11 | Display Investigation | Streamlit Dashboard | Presents risk, findings, attack chain, CTI, ATT&CK, reasoning and response information. |

---

## 2.6 User Stories

### US-01 – Event Normalisation

As a SOC analyst, I want security events to be normalised into a consistent structure so that investigations can be performed using standard fields.

### US-02 – Contextual Detection

As a SOC analyst, I want detection rules to consider the context of an event so that normal administrative activity is not automatically treated as malicious.

### US-03 – Event Correlation

As a SOC analyst, I want related findings to be correlated by time and entity so that potentially connected activities can be investigated together.

### US-04 – Threat Intelligence

As a SOC analyst, I want CTI information associated with relevant findings so that suspicious indicators and techniques can be investigated with additional context.

### US-05 – MITRE ATT&CK Mapping

As a SOC analyst, I want observed activities mapped to MITRE ATT&CK techniques so that the investigation has a recognised behavioural representation.

## US-06 – Risk Assessment

As a SOC analyst, I want an evidence-weighted risk assessment so that the importance of an incident can be understood using multiple evidence sources.

## US-07 – Explainable Reasoning

As a SOC analyst, I want the system to explain its assessment using available evidence so that I can understand how the conclusion was produced.

## US-08 – Response Recommendation

As an incident responder, I want response recommendations with human approval so that potentially disruptive actions are not executed without validation.

## US-09 – Research Evaluation

As a researcher, I want repeatable hold-out, baseline, ablation and stress-test evaluations so that the behaviour of the prototype can be measured systematically.

---

## 2.7 Requirements Engineering

### 2.7.1 Functional Requirements

| ID    | Functional Requirement                                             | Priority |
|-------|--------------------------------------------------------------------|----------|
| FR-01 | The system shall ingest JSON, JSONL and CSV security logs.         | High     |
| FR-02 | The system shall normalise core security-event fields.             | High     |
| FR-03 | The system shall apply context-aware detection rules.              | High     |
| FR-04 | The system shall correlate findings by time and relevant entities. | High     |
| FR-05 | The system shall retrieve relevant CTI information.                | High     |

| <b>ID</b> | <b>Functional Requirement</b>                                                  | <b>Priority</b> |
|-----------|--------------------------------------------------------------------------------|-----------------|
| FR-06     | The system shall map supported findings to MITRE ATT&CK.                       | High            |
| FR-07     | The system shall calculate evidence-weighted risk.                             | High            |
| FR-08     | The system shall represent uncertainty within the risk assessment.             | High            |
| FR-09     | The system shall generate a structured security decision.                      | High            |
| FR-10     | The system shall provide evidence-grounded LLM reasoning.                      | High            |
| FR-11     | The system shall validate LLM reasoning against available evidence.            | Medium          |
| FR-12     | The system shall generate incident-response recommendations.                   | High            |
| FR-13     | The system shall require human approval before disruptive response actions.    | Critical        |
| FR-14     | The system shall display investigation results through a dashboard.            | Medium          |
| FR-15     | The system shall support repeatable evaluation using stored scenario datasets. | Medium          |

---

### 2.7.2 Non-Functional Requirements

| <b>ID</b> | <b>Non-Functional Requirement</b>                                                                          |
|-----------|------------------------------------------------------------------------------------------------------------|
| NFR-01    | The system should support repeatable and deterministic evaluation where applicable.                        |
| NFR-02    | The system should preserve the original security evidence used during investigation.                       |
| NFR-03    | The system should explicitly represent uncertainty and investigative limitations.                          |
| NFR-04    | The system should maintain separation between authoritative risk assessment and generated LLM explanation. |

| <b>ID</b> | <b>Non-Functional Requirement</b>                                                      |
|-----------|----------------------------------------------------------------------------------------|
| NFR-05    | The system should prevent automatic destructive response actions.                      |
| NFR-06    | The system should provide understandable investigation results through the dashboard.  |
| NFR-07    | The architecture should allow individual components to be tested independently.        |
| NFR-08    | The system should support modular extension for future SIEM, EDR and CTI integrations. |

---

## 2.8 Requirement-to-Component Mapping

| <b>Requirement Area</b>    | <b>Responsible Component</b>             |
|----------------------------|------------------------------------------|
| Log ingestion              | Log Ingestor                             |
| Event normalisation        | Log Ingestor                             |
| Detection                  | Detection Engine                         |
| Temporal correlation       | Attack-Chain Module                      |
| Entity correlation         | Attack-Chain Module                      |
| CTI enrichment             | Investigation Agent + CTI Knowledge Base |
| ATT&CK mapping             | MITRE Module                             |
| Risk calculation           | Risk Assessment Agent                    |
| Security decision          | Decision Agent                           |
| Structured reasoning       | AI Reasoning Agent                       |
| Natural-language reasoning | LLM Reasoning Engine                     |

| Requirement Area        | Responsible Component                  |
|-------------------------|----------------------------------------|
| Response recommendation | Response Agent                         |
| Human approval          | Response workflow                      |
| Visualisation           | Streamlit Dashboard                    |
| API orchestration       | FastAPI + SOC Orchestrator             |
| Evaluation              | Evaluation scripts + scenario datasets |

---

## 2.9 Analysis Summary

The analysis establishes that Agentic AI-SOC is not designed as a single detection rule or standalone LLM application. It is a coordinated security-investigation workflow in which different components perform specialised functions.

The analysis also establishes the major design constraints: evidence must be preserved, correlations must be treated as hypotheses, LLM output must remain grounded in available evidence, and disruptive response actions must remain under human control.

These requirements provide the foundation for the architecture and implementation described in **Chapter 3 – Design**.

## 3. Design

### 3.1 Design Techniques

The Agentic AI-SOC platform uses a **modular multi-agent design** in which individual security-analysis functions are separated into specialised components. This approach allows each component to have a clearly defined responsibility and enables individual modules to be tested independently.

The design follows the principle of separating **evidence collection, detection, investigation, assessment, reasoning, decision making, and response recommendation**. This separation is particularly important because the project does not treat the Large Language Model as the authoritative source of security risk.

The main design techniques used are:

#### 3.1.1 Modular Decomposition

The SOC workflow is divided into separate modules such as the Log Ingestor, Detection Engine, Attack-Chain module, Investigation Agent, CTI Knowledge Base, Risk Assessment Agent, Decision Agent, AI Reasoning Agent, LLM Reasoning Engine, and Response Agent.

Each module has a defined input and output, making the overall system easier to test, maintain, and extend.

#### 3.1.2 Evidence-Based Processing

The system carries security evidence through the investigation pipeline rather than immediately converting an event into a final conclusion. This allows the final decision to be linked to the findings that contributed to it.

#### 3.1.3 Context-Aware Detection

Detection rules consider the context of an event. For example, PowerShell activity is not automatically considered malicious because PowerShell is commonly used for legitimate administration. Higher-risk indicators are therefore evaluated separately from common administrative commands.

### 3.1.4 Multi-Stage Correlation

The design correlates multiple findings based on temporal and entity relationships. This allows individually ambiguous events to be analysed as a potential sequence.

### 3.1.5 Human-in-the-Loop Control

Response recommendations are separated from automatic execution. The response layer can recommend actions such as host isolation or investigation of an account, but disruptive actions remain subject to human approval.

### 3.1.6 Grounded LLM Reasoning

The LLM is used to generate natural-language reasoning based on supplied evidence. The authoritative risk assessment remains outside the LLM, reducing the possibility of allowing generated language to independently determine the security risk.

---

## 3.2 System Design Process

The complete processing workflow is designed as a sequential investigation pipeline:

### Step 1 – Log Ingestion and Normalisation

Security events are received in JSON, JSONL, or CSV format. The Log Ingestor converts the input into a consistent internal representation containing relevant fields such as timestamp, event type, source, username, source IP, destination IP, process, command line, message, and the original event data.

### Step 2 – Context-Aware Detection

The Detection Engine evaluates the normalised events against implemented detection rules. The rules identify activities such as:

- PowerShell execution
- System discovery

- Failed authentication
- External network communication
- Multi-stage suspicious activity

The detection stage also considers context so that normal administrative activity is not automatically treated as malicious.

### **Step 3 – Temporal and Entity Correlation**

Detected findings are correlated using a 15-minute investigation window. Relationships can be strengthened through shared entities such as:

- Host
- User
- Source IP
- Destination IP
- Related event characteristics

The resulting relationships are treated as investigative evidence rather than absolute proof.

### **Step 4 – CTI Enrichment**

The Investigation Agent uses the local CTI knowledge base to identify relevant threat-intelligence information. Indicator-based matches and technique-related information are returned as supporting evidence.

### **Step 5 – MITRE ATT&CK Mapping**

Relevant findings are mapped to supported MITRE ATT&CK techniques. This provides a standardised representation of observed security behaviour.

### **Step 6 – Dynamic Risk Assessment**

The Risk Assessment Agent calculates an evidence-weighted risk score. The assessment considers evidence strength, temporal correlation, entity correlation, MITRE coverage, CTI information, contextual modifiers, and uncertainty.

### **Step 7 – Deterministic Security Decision**

The Decision Agent uses the available findings, correlation information, CTI evidence, and authoritative risk assessment to generate a structured security decision:

- **BENIGN**
- **SUSPICIOUS**
- **MALICIOUS**

#### **Step 8 – Structured AI Reasoning**

The AI Reasoning Agent converts the investigation information into a structured explanation containing the relevant evidence, attack-chain interpretation, risk information, and uncertainty.

#### **Step 9 – Evidence-Grounded LLM Reasoning**

The local Llama 3.1 8B model receives the investigation evidence and authoritative risk context. The model generates a natural-language security explanation.

A grounding mechanism then checks whether the generated assessment remains consistent with the supplied evidence.

#### **Step 10 – Response Recommendation**

The Response Agent produces recommended incident-response actions. The system maintains a human-approval state before disruptive actions are performed.

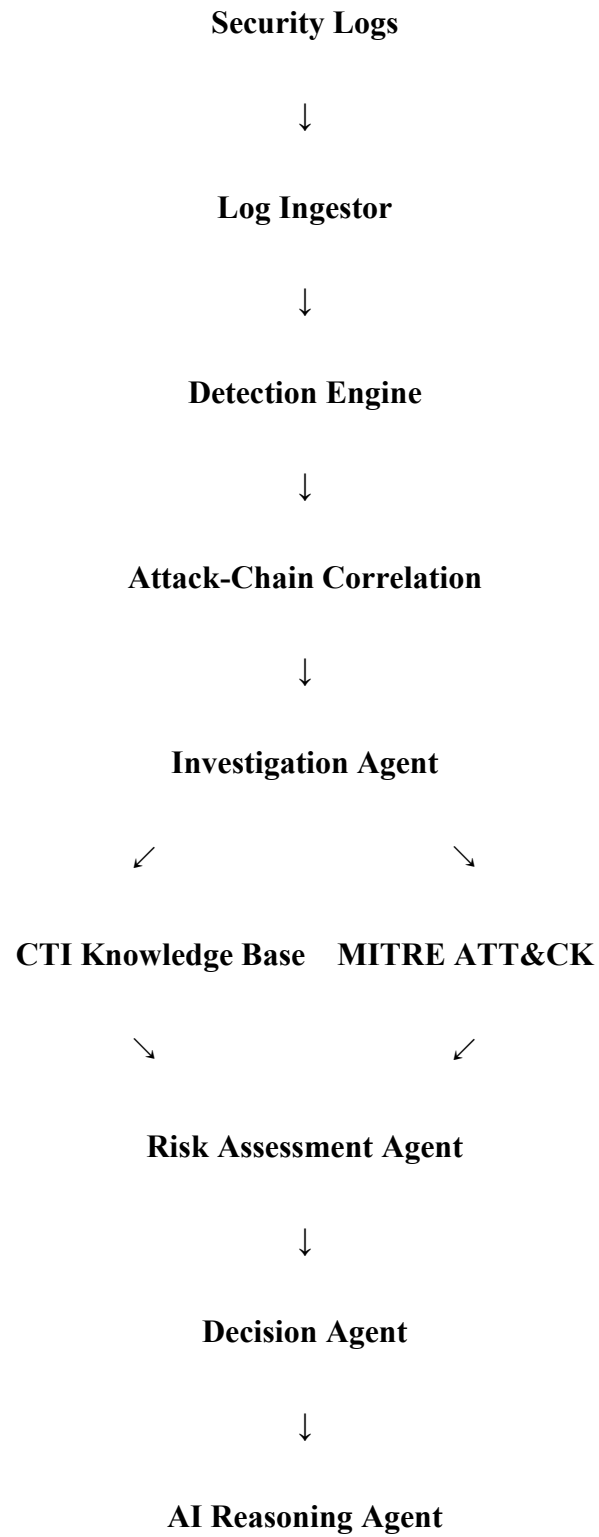
#### **Step 11 – Dashboard Presentation**

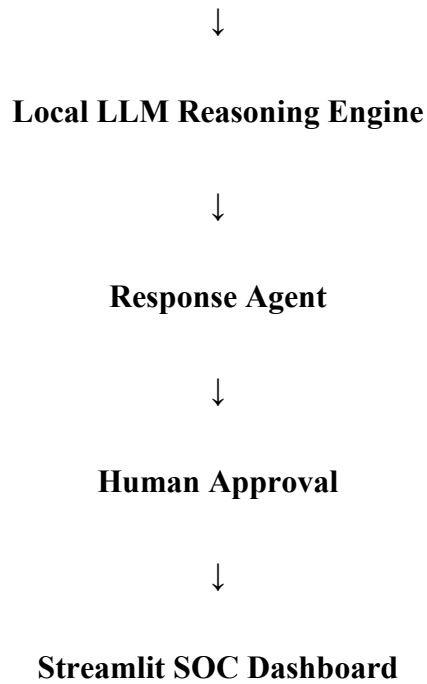
The complete investigation is presented through the Streamlit dashboard. The analyst can view the incident overview, findings, risk assessment, attack chain, MITRE ATT&CK mapping, CTI information, AI reasoning, uncertainty, and response recommendations.

---

### 3.3 System Architecture Overview

The architecture can be represented as:





The FastAPI backend and SOC Orchestrator coordinate the execution of these components.

---

### 3.4 Core System Components

| Component             | Primary Responsibility                    | Main Output                     |
|-----------------------|-------------------------------------------|---------------------------------|
| Log Ingestor          | Parse and normalise security logs         | Normalised events               |
| Detection Engine      | Identify potentially significant activity | Security findings               |
| Attack-Chain Module   | Correlate events temporally and by entity | Relationships and attack stages |
| Investigation Agent   | Combine evidence and enrichment           | Investigation context           |
| CTI Knowledge Base    | Provide indicator and technique context   | CTI matches                     |
| MITRE Module          | Map observations to ATT&CK                | ATT&CK techniques               |
| Risk Assessment Agent | Calculate risk and uncertainty            | Risk score and confidence       |

| Component                   | Primary Responsibility                         | Main Output                 |
|-----------------------------|------------------------------------------------|-----------------------------|
| <b>Decision Agent</b>       | Produce security classification                | Benign/Suspicious/Malicious |
| <b>AI Reasoning Agent</b>   | Generate structured explanation                | Security reasoning          |
| <b>LLM Reasoning Engine</b> | Generate grounded natural-language explanation | LLM assessment              |
| <b>Response Agent</b>       | Generate response recommendations              | Recommended actions         |
| <b>SOC Orchestrator</b>     | Coordinate the complete pipeline               | Complete analysis           |
| <b>FastAPI Backend</b>      | Provide application API                        | API responses               |
| <b>Streamlit Dashboard</b>  | Present investigation results                  | Analyst interface           |

### 3.5 Data Flow Design

The system follows a controlled data flow in which each stage receives information from the previous stage and adds additional security context.

The initial security log contains raw observations. After ingestion, the Log Ingestor creates a normalised representation. The Detection Engine then attaches detection findings to relevant events.

The Attack-Chain module evaluates whether findings are related. Investigation then combines the detected findings with CTI and MITRE information. The Risk Assessment Agent uses this enriched evidence to calculate the authoritative risk.

The Decision Agent then produces the structured security classification. AI reasoning and the local LLM subsequently use the investigation evidence and authoritative risk information to create an explanation.

Finally, the Response Agent generates recommended actions and the dashboard displays the complete investigation.

This design ensures that the LLM is positioned **after evidence collection and risk assessment**, rather than being placed at the beginning of the pipeline as the primary detection mechanism.

---

### 3.6 Attack-Chain Correlation Design

The attack-chain component is designed to identify relationships between findings occurring within a defined **15-minute correlation window**.

The correlation process considers:

1. Temporal proximity.
2. Shared host information.
3. Shared user information.
4. Shared source IP information.
5. Related detection types.
6. Relationship confidence.

For example, a discovery event followed by network activity on the same host may provide stronger investigative context than the same two events occurring on unrelated hosts.

The system therefore distinguishes between stronger same-entity relationships and weaker cross-entity relationships.

Importantly, the resulting attack chain is classified as an **investigative hypothesis**. The system does not assume that correlation automatically proves malicious intent.

---

### 3.7 Risk Assessment Design

The Risk Assessment Agent uses multiple evidence dimensions rather than relying on a single detection rule.

The representative dashboard run produced a dynamic risk score of:

**68 / 100 — HIGH**

The displayed risk components were:

| <b>Risk Component</b>     | <b>Contribution</b> |
|---------------------------|---------------------|
| Evidence Score            | 45                  |
| Temporal Correlation      | 15                  |
| Entity Correlation        | 15                  |
| MITRE Coverage            | 12                  |
| CTI Score                 | 0                   |
| Context Modifier          | -12                 |
| Uncertainty Penalty       | -7                  |
| <b>Final Dynamic Risk</b> | <b>68 / 100</b>     |

The risk model therefore considers both positive and negative evidence. For example, legitimate administrative context can reduce the risk contribution, while stronger suspicious evidence can increase it.

The uncertainty penalty is particularly important because the system recognises that security evidence may not provide complete certainty.

---

### **3.8 Security Decision Design**

The Decision Agent converts the investigation evidence into one of three structured classifications:

**BENIGN**

Used when the available evidence is consistent with normal or legitimate activity and there is insufficient support for a suspicious or malicious interpretation.

### **SUSPICIOUS**

Used when the available evidence requires investigation but does not provide sufficient support for a malicious classification.

### **MALICIOUS**

Used when multiple supporting signals, strong relationships, high-risk behaviour, or strong CTI/contextual evidence provide sufficient support under the implemented decision logic.

The Decision Agent uses the authoritative risk assessment together with findings and correlation information. This prevents the LLM from independently deciding the final security classification.

---

## **3.9 LLM Reasoning Design**

The local LLM component uses **Llama 3.1 8B through Ollama**.

The LLM receives:

- Relevant security findings
- Attack-chain information
- CTI context
- MITRE ATT&CK information
- Authoritative risk score
- Risk level
- Confidence information
- Evidence and uncertainty information

The LLM is instructed to reason only from the supplied investigation context.

The architecture therefore separates:

**Observed Evidence → Risk Assessment → Security Decision**

from:

**Evidence + Risk Context → LLM Explanation**

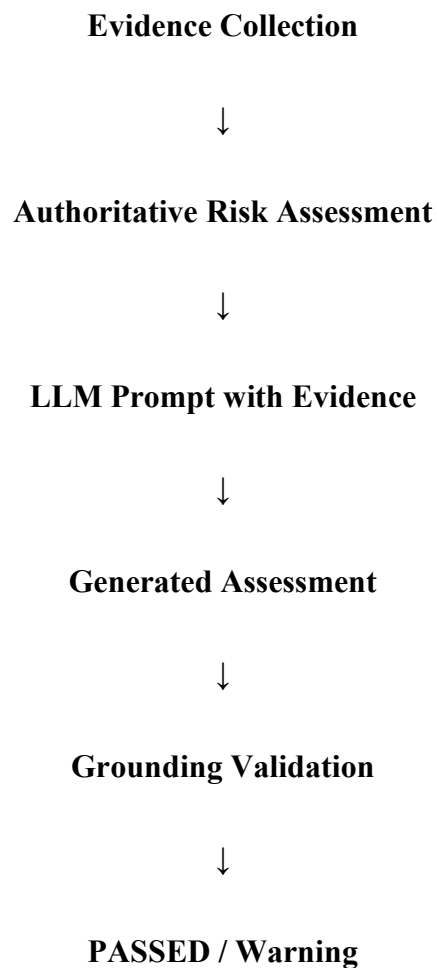
This separation is an important design decision because the LLM provides an explanation layer rather than becoming the authoritative source of security risk.

---

### 3.10 Evidence Grounding Design

The grounding mechanism is designed to identify unsupported claims in generated reasoning.

The process can be summarised as:



The captured dashboard execution reported:

**LLM Evidence Grounding: PASSED**

This status is displayed to the analyst together with the generated assessment.

---

### 3.11 Human-in-the-Loop Response Design

The response architecture deliberately separates **recommendation** from **execution**.

For a high-risk incident, the Response Agent may recommend actions such as:

- Isolating an affected host.
- Blocking a suspicious external destination.
- Reviewing affected user accounts.
- Investigating suspicious PowerShell activity.
- Reviewing system-discovery activity.

However, the system does not automatically execute disruptive actions. Instead, the response state can remain:

**PENDING\_HUMAN\_APPROVAL**

This design reduces the risk of an incorrect automated decision immediately causing operational disruption.

---

### 3.12 Dashboard Design

The Streamlit dashboard is designed to present the investigation as a single analyst-facing view.

The dashboard provides:

- Incident risk score

- Risk level
- Number of findings
- Number of attack stages
- Security decision
- Decision confidence
- Dynamic risk breakdown
- Attack-chain stages
- AI security assessment
- MITRE ATT&CK techniques
- CTI information
- Recommended response actions
- Uncertainty and limitations
- LLM model information
- LLM grounding status

The captured implementation demonstrates a representative **68/100 HIGH-risk** investigation with multiple findings and attack stages.

---

### 3.13 Design Safety and Governance

Several design controls are included to reduce unsafe automation:

1. The LLM does not override the authoritative risk assessment.
2. Correlations are treated as investigative hypotheses.
3. Uncertainty is explicitly represented.
4. Response recommendations require human approval.
5. Evidence is preserved throughout the workflow.
6. The dashboard exposes the reasoning context.
7. The system does not automatically perform destructive containment.

These controls support the project's objective of creating an AI-assisted SOC platform while retaining human responsibility for consequential security actions.

---

### 3.14 Design Summary

The design of Agentic AI-SOC combines deterministic detection, contextual correlation, CTI enrichment, MITRE ATT&CK mapping, evidence-weighted risk assessment, structured decision making, local LLM reasoning, and human-approved response recommendations.

The architecture deliberately separates **evidence collection, authoritative risk assessment, language reasoning, and response execution**. This provides a modular structure that can be evaluated independently and extended in future versions.

The next chapter describes how this design was implemented using Python, FastAPI, Streamlit, Ollama, Llama 3.1 8B, and the project's individual agents and modules.

## 4. Product Implementation

### 4.1 Development Environment

Agentic AI-SOC was implemented as a Python-based research prototype using a local development environment. The system combines a FastAPI backend, Streamlit dashboard, modular Python agents, and a locally hosted Llama 3.1 8B model.

| Item                 | Implementation     |
|----------------------|--------------------|
| Operating System     | Windows 11         |
| Programming Language | Python 3.13        |
| Backend              | FastAPI + Uvicorn  |
| Dashboard            | Streamlit          |
| LLM Runtime          | Ollama             |
| LLM                  | Llama 3.1 8B       |
| Input Formats        | JSON / JSONL / CSV |

The local LLM approach allows the reasoning component to operate locally through Ollama without requiring a paid external API. The application components communicate through the backend orchestration layer, while the Streamlit dashboard provides the analyst-facing interface.

### 4.2 Module Implementation

The implementation is organised into separate modules so that different SOC functions can be developed and tested independently. The main components include backend orchestration, log ingestion, detection, attack-chain reasoning, investigation, CTI, MITRE ATT&CK mapping, risk assessment, security decision making, AI reasoning, response recommendations, and dashboard presentation.

The **Detection Engine** implements context-aware rules for PowerShell activity, system discovery, failed authentication, external network communication, and multi-stage suspicious activity. An important implementation feature is contextual PowerShell classification. Common administrative commands are not automatically treated as high-risk activity, while commands containing higher-risk execution or download indicators receive stronger detection treatment.

The **Attack-Chain module** correlates findings using a 15-minute window and considers relationships involving hosts, users, source IPs, and event timing.

The **Investigation and CTI components** enrich detected findings with relevant threat-intelligence information, while the MITRE ATT&CK component provides technique-level context.

The **Risk Assessment Agent** combines evidence, temporal and entity relationships, MITRE coverage, CTI information, context, and uncertainty to calculate the authoritative risk assessment.

The **Decision Agent** then produces a structured BENIGN, SUSPICIOUS, or MALICIOUS classification. The LLM is used as an explanation component and does not independently override the authoritative risk assessment.

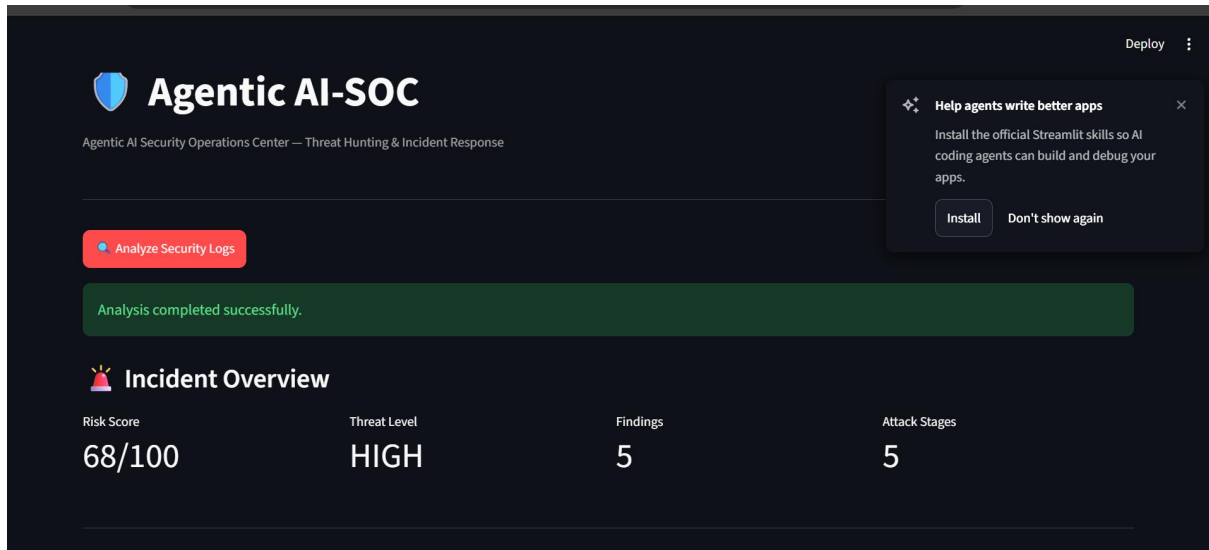
### 4.3 Dashboard Implementation

The Streamlit dashboard provides a consolidated view of the security investigation. Instead of requiring the analyst to inspect each backend component separately, the dashboard presents the main investigation results in a single interface.

The dashboard includes:

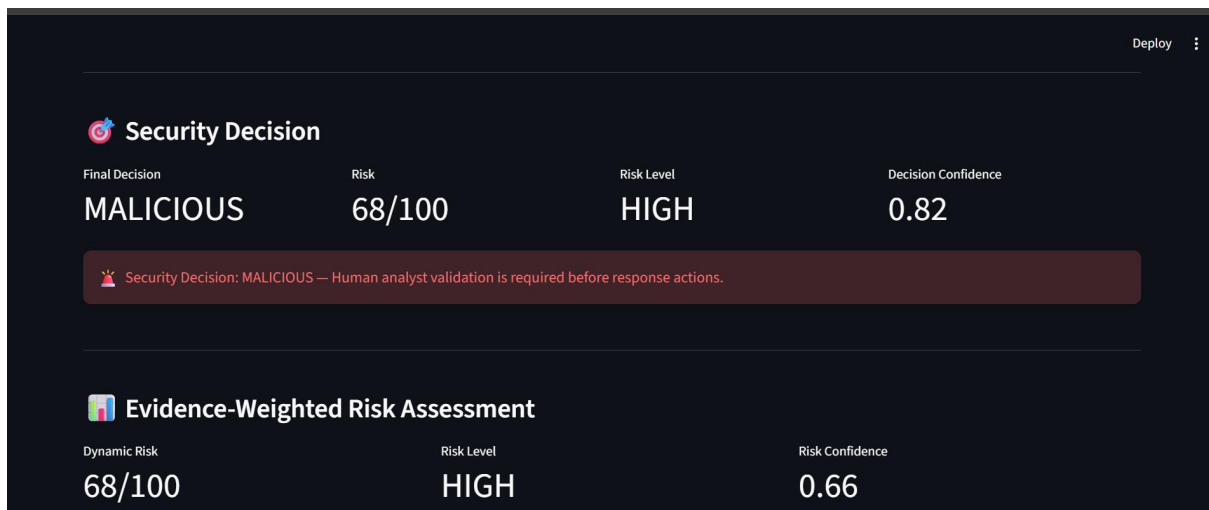
- Incident overview
- Risk score and risk level
- Security decision and confidence
- Dynamic risk breakdown
- Attack-chain stages
- AI security assessment
- Key security evidence
- MITRE ATT&CK techniques

- Cyber Threat Intelligence information
- Incident-response recommendations
- Evidence and uncertainty information
- LLM grounding status



This view provides the overall status of the analysed security incident, including the calculated risk level, number of findings, attack stages, and final security decision.

*Figure 1. Agentic AI-SOC Dashboard – Incident Overview.*



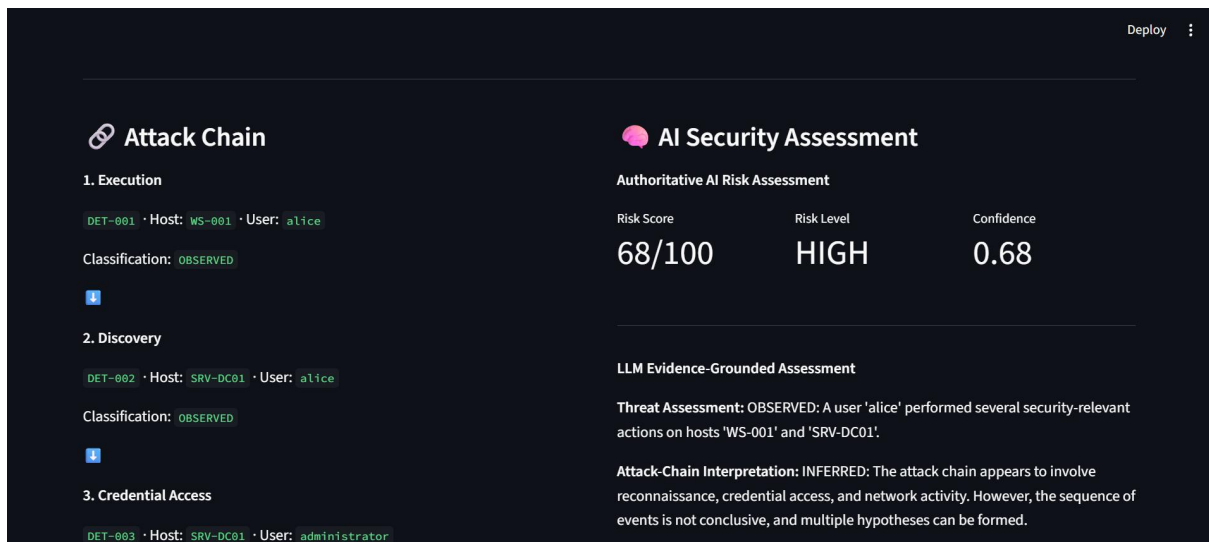
This section presents the structured security decision together with the associated risk level and confidence, allowing the analyst to quickly understand the current assessment.

***Figure 2. Security Decision and Risk Level.***



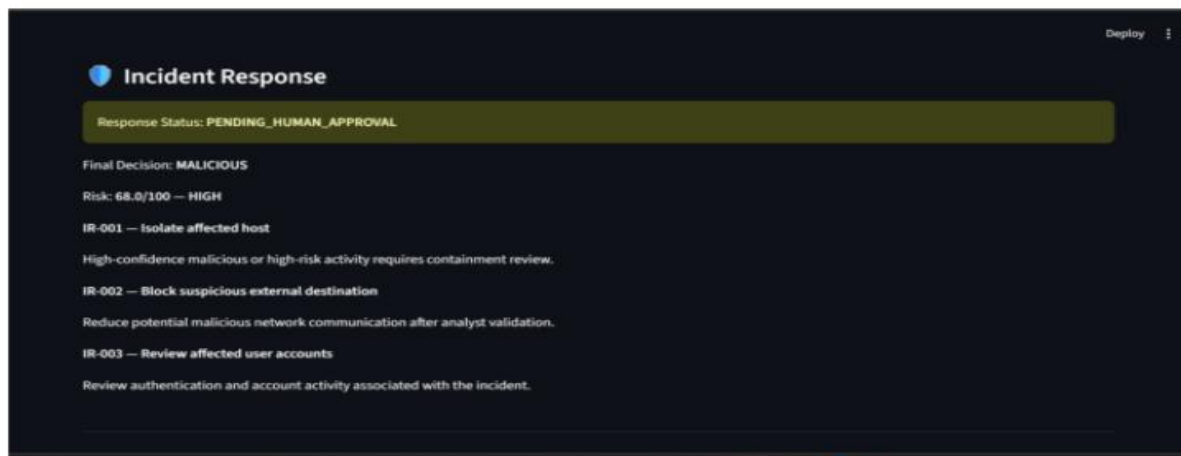
The dashboard displays how the final risk score was constructed from different evidence components. This improves transparency because the analyst can see which factors contributed to or reduced the overall risk.

***Figure 3. Evidence-Weighted Dynamic Risk Assessment.***



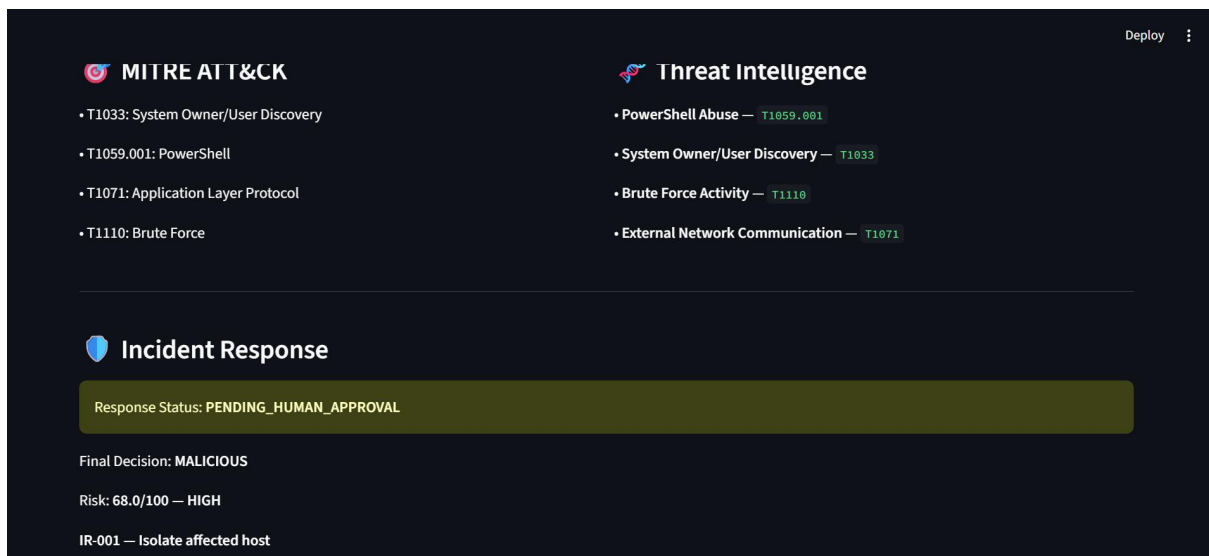
This view presents the correlated attack stages and the structured AI assessment. The attack chain helps the analyst understand how individual findings may be related within the investigation window.

*Figure 4. Attack Chain and AI Security Assessment.*



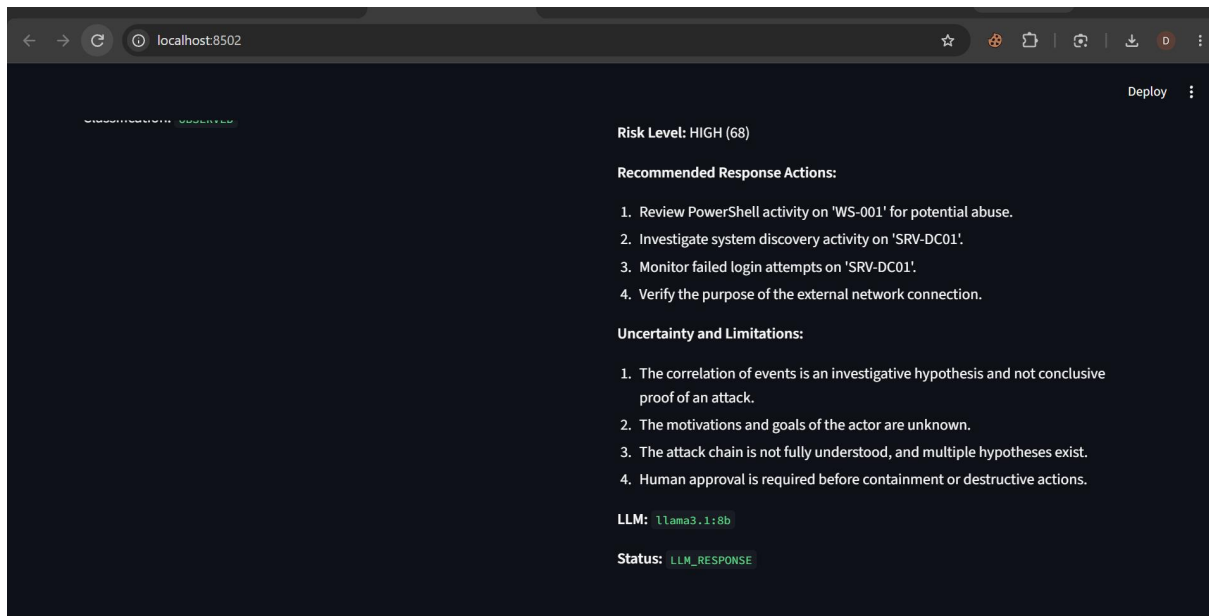
This view presents the recommended incident-response actions for the investigated security incident. The response status remains PENDING\_HUMAN\_APPROVAL, and the recommended actions include isolating the affected host, blocking the suspicious external destination, and reviewing affected user accounts. These actions require analyst validation before execution.

*Figure 5. Incident Response Recommendations.*



This dashboard section presents the MITRE ATT&CK techniques identified during the investigation together with the available Threat Intelligence enrichment and the incident-response status. It provides behavioural and threat-intelligence context while showing that the recommended response remains subject to human approval.

**Figure 6. MITRE ATT&CK, Threat Intelligence and Incident Response Dashboard.**



This section presents the recommended response actions for the investigated security incident together with the associated uncertainty and limitations. The recommendations include reviewing

suspicious PowerShell activity, investigating system-discovery activity, monitoring failed login attempts, and verifying the purpose of the external network connection. The response actions remain subject to human approval rather than being executed automatically.

***Figure 7. Incident Response Recommendations, Uncertainty and LLM Status.***

The final dashboard section exposes evidence, investigation uncertainty, LLM information, and grounding status. The captured execution reports **LLM Evidence Grounding: PASSED**, indicating that the generated explanation passed the implemented grounding check.

**Note:** The screenshots in this section provide visual evidence of the implemented dashboard and its end-to-end investigation output.

#### **4.4 Local LLM and Evidence Grounding**

Ollama hosts Llama 3.1 8B locally. The LLM does not override the authoritative risk agent. It receives evidence and risk context and produces a grounded explanation. The captured run reports LLM Evidence Grounding: PASSED.

## 5. Validation

### 5.1 Validation Strategy

The Agentic AI-SOC platform was validated using multiple evaluation approaches to assess both functional correctness and the behaviour of the proposed architecture. The validation strategy included functional testing, unseen hold-out evaluation, comparison with a rule-based baseline, component-level ablation testing, stress testing, and end-to-end dashboard validation.

The **45-scenario hold-out dataset** was used as the primary evaluation set. These scenarios were kept separate from the development logic to provide an unseen evaluation of the implemented system. A rule-based baseline was then evaluated using the same scenarios to provide a direct comparison.

Ablation experiments were conducted by selectively removing major components such as attack-chain reasoning, CTI enrichment, context-aware detection, and dynamic risk assessment. Additional stress scenarios were used to examine the behaviour of the decision logic under a wider range of security-event combinations.

The validation therefore evaluates not only the final classification performance, but also the contribution of individual architectural components and the successful operation of the complete SOC workflow.

---

### 5.2 Hold-out Evaluation

The primary evaluation used **45 synthetic unseen hold-out scenarios** consisting of benign, malicious, suspicious, and benign-with-noise cases.

| Metric    | Result |
|-----------|--------|
| Scenarios | 45     |
| TP        | 20     |

| Metric              | Result   |
|---------------------|----------|
| TN                  | 25       |
| FP                  | 0        |
| FN                  | 0        |
| Accuracy            | 100.00%  |
| Precision           | 100.00%  |
| Recall              | 100.00%  |
| F1-Score            | 100.00%  |
| False Positive Rate | 0.00%    |
| MITRE Precision     | 84.62%   |
| MITRE Recall        | 100.00%  |
| MITRE F1-Score      | 91.67%   |
| Average Latency     | ~0.001 s |

The complete Agentic AI-SOC correctly classified all 45 evaluated scenarios under the implemented binary evaluation criteria. No false positives or false negatives were recorded in this hold-out experiment.

MITRE ATT&CK mapping achieved **84.62% precision, 100% recall, and 91.67% F1-score**, indicating that the system successfully identified the relevant techniques in the evaluated scenarios, while some additional technique predictions were not counted as correct.

The measured average processing latency was approximately **0.001 seconds** for the evaluated pipeline components. This latency should be interpreted as implementation-level processing time for the synthetic evaluation environment rather than as an end-to-end production SOC response time.

**Important limitation:** These results apply only to the constructed 45 synthetic unseen hold-out scenarios. Therefore, the 100% classification metrics should **not** be interpreted as real-world operational accuracy or as evidence that the system would achieve the same performance on production SOC data.

---

### 5.3 Baseline Comparison

A rule-based baseline was implemented and evaluated using the same 45 hold-out scenarios.

| Metric          | Rule-Based Baseline | Agentic AI-SOC |
|-----------------|---------------------|----------------|
| Accuracy        | 88.89%              | 100.00%        |
| Precision       | 100.00%             | 100.00%        |
| Recall          | 75.00%              | 100.00%        |
| F1-Score        | 85.71%              | 100.00%        |
| FPR             | 0.00%               | 0.00%          |
| MITRE Precision | 84.62%              | 84.62%         |
| MITRE Recall    | 100.00%             | 100.00%        |
| MITRE F1-Score  | 91.67%              | 91.67%         |

The rule-based baseline produced **five false negatives** on the same hold-out dataset. The Agentic AI-SOC detected these scenarios using its contextual detection and multi-stage reasoning mechanisms.

Compared with the baseline, the complete system showed:

- **Accuracy:** +11.11 percentage points
- **Recall:** +25.00 percentage points
- **F1-score:** +14.29 percentage points

- **Precision:** unchanged at 100%
- **False Positive Rate:** unchanged at 0%

The comparison suggests that the additional contextual and correlation mechanisms helped reduce missed detections in the evaluated scenarios. However, this conclusion is limited to the constructed evaluation dataset.

MITRE ATT&CK mapping results were identical for both approaches because the evaluated mapping logic was not changed between the baseline and complete-system comparison.

---

## 5.4 Ablation Evaluation

Ablation testing was performed to examine the contribution of selected system components. Each experiment removed or disabled one component while keeping the remaining architecture unchanged.

| Configuration   | Accuracy | Recall | F1     | MITRE F1 |
|-----------------|----------|--------|--------|----------|
| Full System     | 1.0000   | 1.0000 | 1.0000 | 0.9167   |
| No Attack Chain | 0.8889   | 0.7500 | 0.8571 | 0.0000   |
| No CTI          | 1.0000   | 1.0000 | 1.0000 | 0.9167   |
| No Context      | 0.5556   | 0.0000 | 0.0000 | 0.9167   |
| No Risk         | 1.0000   | 1.0000 | 1.0000 | 0.9167   |

The ablation results show that **attack-chain reasoning and context-aware detection had a measurable effect on the classification results** for this hold-out dataset.

Removing attack-chain reasoning reduced recall from 1.0000 to 0.7500 and F1-score from 1.0000 to 0.8571. This indicates that temporal and event relationships contributed to the detection of some scenarios that were not adequately identified by isolated event analysis.

The removal of context-aware detection produced a larger reduction, with accuracy decreasing to 0.5556 and recall and F1-score reaching 0. This demonstrates that the contextual classification of security events was important for the specific scenarios included in this experiment.

Removing CTI enrichment or dynamic risk assessment did not change the measured classification metrics on this particular hold-out dataset. This does **not** demonstrate that these components are unnecessary. Rather, it indicates that their contribution was not reflected in the selected classification metrics and scenarios. Broader and more diverse datasets would be required to evaluate their independent contribution more reliably.

---

## 5.5 Stress Testing

A separate stress-test dataset containing **30 scenarios** was used to examine the behaviour of the decision logic under additional combinations of malicious, suspicious, and benign activities.

| Metric    | Result  |
|-----------|---------|
| Scenarios | 30      |
| TP        | 15      |
| TN        | 15      |
| FP        | 0       |
| FN        | 0       |
| Accuracy  | 100.00% |
| Precision | 100.00% |
| Recall    | 100.00% |
| F1-Score  | 100.00% |

| Metric          | Result     |
|-----------------|------------|
| FPR             | 0.00%      |
| MITRE F1        | 100.00%    |
| Average Latency | 0.000492 s |

Under the binary evaluation criteria, the stress-test results produced 100% accuracy, precision, recall and F1-score with no recorded false positives or false negatives.

However, the detailed multiclass results provide an important qualification. **Two benign stress-test scenarios were classified as SUSPICIOUS rather than BENIGN.** Therefore, the results should not be described as demonstrating perfect multiclass classification.

This distinction is important because a binary evaluation can treat both BENIGN and SUSPICIOUS as non-malicious outcomes, while a multiclass evaluation distinguishes between the two categories.

---

## 5.6 Dashboard Validation

The implemented dashboard was validated through a complete end-to-end execution of the Agentic AI-SOC pipeline.

The captured execution successfully completed the following sequence:

**Log Ingestion → Detection → Attack-Chain Reasoning → Investigation → Risk Assessment → Security Decision → LLM Reasoning → Response Recommendation**

The dashboard displayed:

- **Risk:** 68/100
- **Risk Level:** HIGH
- **Findings:** 5
- **Attack Stages:** 5
- **Security Decision:** MALICIOUS

- **Decision Confidence:** 0.82
- **Dynamic Risk Confidence:** 0.66
- **LLM Assessment:** HIGH
- **LLM Risk:** 68
- **LLM Confidence:** 0.66
- **MITRE Techniques:** T1033, T1059.001, T1071 and T1110
- **CTI Entries:** 4
- **Response Status:** PENDING\_HUMAN\_APPROVAL
- **LLM Evidence Grounding:** PASSED

The dashboard validation demonstrates that the individual components were successfully connected into a single investigation workflow. The response layer did not automatically execute containment actions; instead, the system produced recommendations requiring human approval.

This supports the project's **human-in-the-loop** design, where automated reasoning assists the security analyst while consequential response actions remain under human control.

---

## 5.7 Validation Summary

Overall, the validation results demonstrate that the implemented research prototype operated successfully across functional, comparative, component-level and stress-testing experiments.

The **45-scenario hold-out evaluation** produced 100% classification metrics under the implemented evaluation criteria, while the rule-based baseline achieved 88.89% accuracy and 75.00% recall. The ablation experiments further indicated that attack-chain reasoning and context-aware detection had a measurable effect on the selected hold-out scenarios.

At the same time, the evaluation has important limitations. The datasets are synthetic and relatively small, the classification logic is tailored to the implemented scenarios, and the stress-test results include two benign-to-suspicious classifications that are hidden by the binary evaluation. Therefore, the results demonstrate **technical feasibility and behaviour of the prototype**, rather than generalisable real-world SOC performance.

## 6. Critical Review & Conclusion

### 6.1 Critical Review

The Agentic AI-SOC prototype demonstrates an integrated security-analysis workflow in which deterministic detection, contextual reasoning, event correlation, threat intelligence, MITRE ATT&CK mapping, risk assessment, and AI-assisted explanation operate as connected components.

One of the main strengths observed during validation was the ability to combine individual security findings into a broader investigation context. The ablation results showed that removing attack-chain reasoning reduced the hold-out recall from **100.00% to 75.00%**, while removing context-aware detection resulted in a substantially larger reduction in the measured classification performance. These results indicate that, within the evaluated scenarios, contextual and correlation-based processing contributed to the final security decisions.

The baseline comparison also demonstrated a measurable difference between isolated rule-based detection and the complete implemented workflow. The rule-based baseline achieved **88.89% accuracy and 75.00% recall**, whereas the complete Agentic AI-SOC achieved **100.00% accuracy and 100.00% recall** on the same synthetic hold-out dataset. However, these results should be interpreted as experimental results from the constructed dataset rather than as evidence of general real-world superiority.

A further strength of the system is its separation between authoritative security assessment and LLM-generated explanation. The local Llama 3.1 8B model is not allowed to independently override the calculated risk assessment. Instead, it receives investigation evidence and risk context and generates an evidence-grounded explanation. The implementation also provides an explicit grounding status, which was **PASSED** during the captured dashboard execution.

The human-in-the-loop design is another important aspect of the prototype. The Response Agent generates recommended actions such as host isolation, external destination blocking, and account review, but these actions remain **PENDING\_HUMAN\_APPROVAL**. This reduces the risk of allowing an experimental AI component to perform consequential security actions without analyst oversight.

Despite these strengths, several limitations remain. The most significant limitation is the use of **synthetic evaluation scenarios**. Although the 45-scenario hold-out dataset was unseen during the evaluation process, it remains a constructed dataset and therefore may not represent the diversity, noise, ambiguity, and scale of enterprise security telemetry.

The local CTI knowledge base is also limited compared with continuously updated commercial or community threat-intelligence platforms. Similarly, the current response component provides recommendations rather than direct integration with enterprise endpoint, firewall, identity, SIEM, SOAR, or ticketing infrastructure.

Another limitation is that the measured latency represents the current local implementation and synthetic test environment. It should not be interpreted as an expected production SOC response time, particularly when external data sources, large-scale log volumes, network communication, or human approval processes are introduced.

Finally, the 100% classification result must be interpreted carefully. The stress-test experiment also showed that two benign scenarios were classified as **SUSPICIOUS**, even though the binary evaluation treated them as non-malicious. This demonstrates why binary metrics alone are insufficient for describing the complete multiclass behaviour of the system.

---

## 6.2 Key Findings

The main findings from the implementation and validation activities are:

1. The complete prototype successfully integrates log ingestion, detection, investigation, correlation, CTI, MITRE ATT&CK mapping, risk assessment, AI reasoning, and response recommendation.
2. The Agentic AI-SOC achieved **100.00% accuracy, precision, recall and F1-score** on the evaluated 45-scenario synthetic hold-out dataset.
3. The rule-based baseline achieved **88.89% accuracy, 75.00% recall and 85.71% F1-score** on the same dataset.
4. Attack-chain reasoning contributed to the evaluated classification performance, with its removal reducing recall from **100.00% to 75.00%**.

5. Context-aware detection had a substantial effect in the ablation experiment, although the result is specific to the selected scenarios.
6. MITRE ATT&CK mapping achieved **91.67% F1-score** on the hold-out evaluation.
7. The local LLM successfully generated an evidence-grounded security explanation while the authoritative risk assessment remained under deterministic system control.
8. The response workflow maintained human approval rather than automatically executing potentially disruptive security actions.

These findings demonstrate the technical feasibility of the proposed architecture while also highlighting the need for broader validation.

---

## 6.3 Future Work

Several improvements can be considered for future development.

### 6.3.1 Larger and Independent Datasets

Future evaluations should use larger and independently sourced datasets containing realistic enterprise security telemetry. This would help determine whether the observed performance generalises beyond the constructed synthetic scenarios.

### 6.3.2 Real-Time Security Data

The current prototype can be extended to consume real-time telemetry from SIEM, endpoint, authentication, network, and cloud-security sources. This would allow evaluation under continuous monitoring conditions.

### 6.3.3 Expanded Threat Intelligence

The CTI component can be extended with larger and continuously updated intelligence sources. Future versions could incorporate additional IOC types, reputation information, malware intelligence, vulnerability information, and external CTI feeds.

### 6.3.4 Improved Risk Calibration

The risk-assessment component could be evaluated using larger datasets and calibrated probability or confidence models. This would allow future versions to provide more reliable risk and confidence estimates across different incident categories.

### 6.3.5 Advanced Attack-Graph Reasoning

The current temporal and entity-based attack-chain approach could be extended into a richer attack graph containing hosts, users, processes, IP addresses, techniques, and relationships. This could improve investigation of complex multi-stage incidents.

### 6.3.6 Production SOC Integration

Future development could integrate the response layer with production security technologies such as SIEM, EDR, firewalls, identity systems, ticketing platforms, and SOAR systems. Any automated response integration should retain appropriate approval and safety controls.

### 6.3.7 Improved Multiclass Evaluation

Future experiments should report separate **BENIGN, SUSPICIOUS and MALICIOUS** classification metrics rather than relying primarily on binary evaluation. This would provide a more complete assessment of the decision agent.

---

## 6.4 Closing Executive Summary

Agentic AI-SOC implements a complete research-oriented SOC workflow that combines **log ingestion, contextual threat detection, temporal and entity-based correlation, Cyber Threat Intelligence, MITRE ATT&CK mapping, dynamic risk assessment, security decision making, local LLM reasoning, and human-approved incident response** within a single platform.

The prototype demonstrates how deterministic security controls and AI-assisted reasoning can be combined while maintaining evidence visibility, uncertainty awareness and human oversight.

The experimental results indicate that the implemented architecture performed strongly on the constructed evaluation scenarios. However, the results are appropriately interpreted as evidence of

**prototype feasibility and evaluated system behaviour**, rather than proof of general real-world SOC performance.

---

## 6.5 Conclusion

This project successfully designed, implemented and demonstrated an **Agentic AI-SOC research prototype** for supporting automated threat investigation and incident-response decision making.

The system addresses several limitations of isolated rule-based security analysis by combining contextual detection, multi-stage attack-chain correlation, CTI enrichment, MITRE ATT&CK mapping, evidence-weighted risk assessment, AI-assisted explanation and human-controlled response recommendations.

The validation process demonstrated successful end-to-end operation of the proposed architecture. On the 45-scenario synthetic hold-out evaluation, the system achieved **100.00% accuracy, precision, recall and F1-score**, while the implemented rule-based baseline achieved **88.89% accuracy, 75.00% recall and 85.71% F1-score**. The ablation experiments further demonstrated that attack-chain reasoning and context-aware processing affected the measured performance of the system.

The project also demonstrates an important design principle: **AI reasoning should support security analysts rather than replace security governance and human judgement**. By keeping the authoritative risk assessment separate from the LLM explanation and requiring human approval for response actions, the prototype provides a controlled approach to AI-assisted SOC operations.

Overall, the project provides a practical foundation for further research into multi-agent security operations. Future work should focus on larger independent datasets, realistic enterprise telemetry, continuously updated CTI, improved risk calibration, richer attack-graph reasoning, multiclass evaluation and controlled integration with real-world SOC technologies.

## References / Bibliography

Alaeifar, P., Pal, S., Jadidi, Z., Hussain, M. and Foo, E. (2024) ‘Current approaches and future directions for Cyber Threat Intelligence sharing: A survey’, *Journal of Information Security and Applications*, 83, 103786. Available at: <https://doi.org/10.1016/j.jisa.2024.103786> (Accessed: 24 September 2026).

FastAPI (2026) *FastAPI Documentation*. Available at: <https://fastapi.tiangolo.com/> (Accessed: 24 September 2026).

Habibzadeh, A., Feyzi, F. and Ebrahimi Atani, R. (2026) ‘Large Language Models for Security Operations Centers: A Comprehensive Survey’, *Journal of Electrical and Computer Engineering*, 2026, 3383674. Available at: <https://doi.org/10.1155/jece/3383674> (Accessed: 24 September 2026).

MITRE (2026) *MITRE ATT&CK® Enterprise Matrix*. Available at: <https://attack.mitre.org/matrices/enterprise/> (Accessed: 24 September 2026).

Nelson, A., Rekhi, S., Souppaya, M. and Scarfone, K. (2025) *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile*. NIST Special Publication 800-61 Rev. 3. Gaithersburg, MD: National Institute of Standards and Technology. Available at: <https://doi.org/10.6028/NIST.SP.800-61r3> (Accessed: 24 September 2026).

Ollama (2026) *Ollama Documentation*. Available at: <https://docs.ollama.com/> (Accessed: 24 September 2026).

Python Software Foundation (2026) *Python 3 Documentation*. Available at: <https://docs.python.org/3/> (Accessed: 24 September 2026).

Ribeiro, M.T., Singh, S. and Guestrin, C. (2016) “‘Why Should I Trust You?’: Explaining the Predictions of Any Classifier”, *Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, pp. 1135–1144. Available at: <https://doi.org/10.1145/2939672.2939778> (Accessed: 24 September 2026).

Rieger, M., Shah, A., Alam, A. and Hossain, M.J. (2026) ‘Possibilities and limitations of using large language models (LLMs) for alert classification and prioritisation in security operations centers (SOCs)’, *Expert Systems with Applications*, 331, 133194. Available at: <https://doi.org/10.1016/j.eswa.2026.133194> (Accessed: 24 September 2026).

Streamlit (2026) *Streamlit Documentation*. Available at: <https://docs.streamlit.io/> (Accessed: 24 September 2026).

Tabassi, E. (2023) *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*. NIST AI 100-1. Gaithersburg, MD: National Institute of Standards and Technology. Available at: <https://doi.org/10.6028/NIST.AI.100-1> (Accessed: 24 September 2026).

Vidara, D.R. (2026) *Agentic AI-SOC: Autonomous Threat Hunting, Attack-Chain Reasoning & Incident Response Platform*. Unpublished research prototype, source code, synthetic datasets and evaluation artefacts.

## Appendices

### Appendix A: Project Directory Structure

The following directory structure was used to separate the major components of the Agentic AI-SOC research prototype:

```
agentic-ai-soc/  
|  
├── backend/  
├── agents/  
├── detection/  
├── threat_intel/  
├── mitre/  
├── attack_graph/  
├── response/  
├── dashboard/  
├── data/  
├── models/  
├── tests/  
├── config/  
|  
├── requirements.txt  
└── README.md
```

The modular structure separates security detection, investigation, intelligence enrichment, reasoning, response, evaluation and presentation components. This organisation supports independent testing and future extension of individual modules.

---

### Appendix B: Evaluation Artifacts

The following evaluation artefacts were generated and maintained during the validation process:

- holdout\_scenarios.json
- holdout\_evaluation\_results.json
- baseline\_evaluation\_results.json

- ablation\_evaluation\_results.json
- stress\_test\_scenarios.json
- stress\_test\_evaluation\_results.json

These files contain the scenario definitions and corresponding evaluation outputs used to calculate the reported validation metrics.

The hold-out artifacts support the primary evaluation, while the baseline and ablation artifacts support comparative and component-level analysis. The stress-test artifacts contain additional scenarios used to examine the behaviour of the implemented decision logic.

---

## Appendix C: Demonstration Note

The figures presented in **Chapter 4** were captured from the locally running Streamlit dashboard following successful execution of the Agentic AI-SOC pipeline using the sample security logs.

The demonstration covered the complete processing workflow:

**Log Ingestion → Detection → Attack-Chain Correlation → Investigation → Risk Assessment → Decision → LLM Reasoning → Response Recommendation**

The captured dashboard displayed the resulting risk assessment, security decision, attack-chain information, MITRE ATT&CK techniques, CTI enrichment, response recommendations, evidence information and LLM grounding status.

The response stage remained **PENDING\_HUMAN\_APPROVAL**, consistent with the human-in-the-loop design of the prototype.

---

## Appendix D: Research Caveat

The evaluation results reported in this project are tied to the defined synthetic scenario datasets and the decision logic implemented during the research period.

Although the hold-out scenarios were separated from the development evaluation process, they remain synthetic and therefore may not fully represent the complexity, noise, class imbalance and ambiguity of real enterprise security telemetry.

Future validation should therefore include:

- Independently generated evaluation scenarios
- Realistic or anonymised enterprise security telemetry
- Larger and more diverse datasets
- Class-imbalanced security-event distributions
- Adversarial and evasive attack scenarios
- Previously unseen attack behaviours
- Multiclass evaluation of BENIGN, SUSPICIOUS and MALICIOUS outcomes
- External and continuously updated CTI sources
- Evaluation across different infrastructure and SOC environments

Consequently, the reported performance should be interpreted as evidence of the **technical behaviour and feasibility of the research prototype**, rather than as a guarantee of equivalent performance in production SOC environments.

---

## Appendix E: Key Demonstration Configuration

For reproducibility, the main demonstration environment used the following configuration:

| Component        | Configuration     |
|------------------|-------------------|
| Operating System | Windows 11        |
| Python           | 3.13              |
| Backend          | FastAPI + Uvicorn |
| Dashboard        | Streamlit         |

| Component              | Configuration                   |
|------------------------|---------------------------------|
| LLM Runtime            | Ollama                          |
| Local LLM              | Llama 3.1 8B                    |
| Input Formats          | JSON, JSONL, CSV                |
| Primary Evaluation Set | 45 synthetic hold-out scenarios |
| Stress Test Set        | 30 scenarios                    |
| Response Mode          | Human Approval Required         |